UNCLASSIFIED // FOR OFFICIAL USE ONLY

AUTHORITY TO OPERATE PACKAGE

Income Risk Scoring System

Version 1.0

Field	Value
Sponsoring Agency	U.S. Department of XXXX, Office of XXXX, Credit Check Division
System Name	Income Risk Scoring System (IRSS)
System Version	1.0
System Owner	Raghunath Devayajanam
Role	AI Architect
Classification	UNCLASSIFIED
FIPS 199 Impact Level	Moderate
ATO Package Date	March 2026
Package Version	1.0
Framework References	NIST SP 800-18 Rev. 1 | NIST SP 800-30 Rev. 1 | NIST SP 800-53 Rev. 5 | NIST AI RMF 1.0 | FIPS 199 | FIPS 200 | E-Government Act of 2002

NOTICE: This document is a portfolio demonstration artifact. The sponsoring agency named above is fictional and used solely to illustrate federal ATO documentation structure. All technical content reflects a real, functioning MLOps pipeline built on 2023 U.S. Census Bureau public microdata.

Document Control

Revision History

Version	Date	Author	Description
1.0	March 2026	Raghunath Devayajanam	Initial ATO package — all six components drafted against Virginia (FIPS 51) development deployment.

Document Purpose

This Authority to Operate (ATO) package documents the security posture, privacy considerations, risk assessment, open weaknesses, AI-specific impacts, and security testing approach for the Income Risk Scoring System (IRSS) v1.0. It is structured in accordance with the NIST Risk Management Framework (RMF) as defined in NIST SP 800-37 Rev. 2 and references applicable controls from NIST SP 800-53 Rev. 5.

The package comprises six components:

- Part 1 — System Security Plan (SSP): NIST SP 800-18 Rev. 1
- Part 2 — Privacy Impact Assessment (PIA): E-Government Act of 2002, Section 208
- Part 3 — Risk Assessment Report (RAR): NIST SP 800-30 Rev. 1
- Part 4 — Plan of Action and Milestones (POA&M)
- Part 5 — AI Impact Assessment: EO 13960, OMB M-21-06, NIST AI RMF 1.0
- Part 6 — Security Assessment Plan (SAP): NIST SP 800-53A Rev. 5

Applicable Laws, Regulations, and Standards

Reference	Title
FISMA (44 U.S.C. § 3551)	Federal Information Security Modernization Act
FIPS 199	Standards for Security Categorization of Federal Information and Information Systems
FIPS 200	Minimum Security Requirements for Federal Information and Information Systems
NIST SP 800-18 Rev. 1	Guide for Developing Security Plans for Federal Information Systems
NIST SP 800-30 Rev. 1	Guide for Conducting Risk Assessments
NIST SP 800-37 Rev. 2	Risk Management Framework for Information Systems and Organizations
NIST SP 800-53 Rev. 5	Security and Privacy Controls for Information Systems and Organizations
NIST SP 800-53A Rev. 5	Assessing Security and Privacy Controls in Information Systems and Organizations
NIST AI RMF 1.0	Artificial Intelligence Risk Management Framework

Reference	Title
E-Government Act of 2002, Section 208	Privacy Impact Assessment Requirements
Executive Order 13960	Promoting the Use of Trustworthy Artificial Intelligence in the Federal Government
OMB M-21-06	Guidance for Regulation of Artificial Intelligence Applications

Part 1 — System Security Plan (SSP)

Reference: NIST SP 800-18 Rev. 1 | NIST SP 800-53 Rev. 5 | FIPS 199 | FIPS 200

1.1 System Identification

Attribute	Value
System Name	Income Risk Scoring System (IRSS)
System Acronym	IRSS
System Version	1.0
System Owner	Raghunath Devayajanam, AI Architect
Sponsoring Organization	U.S. Department of XXXX, Office of XXXX, Credit Check Division
Operating Status	Operational — Virginia (FIPS 51) pilot deployment
System Type	Major Application — AI/ML Production Pipeline
Deployment Environment	Amazon Web Services (AWS), us-east-1
Repository	github.com/ai-systems-architect/responsible-mlops-risk-engine
ATO Date	March 2026
ATO Expiration	March 2028 (24-month ATO cycle)

1.2 System Categorization — FIPS 199

The system is categorized in accordance with FIPS 199 and NIST SP 800-60 Vol. I and II. The overall impact level is the high water mark across the three security objectives.

Security Objective	Impact Level	Rationale
Confidentiality	Low	The system is trained on 2023 U.S. Census Bureau ACS PUMS public microdata. No personally identifiable information (PII) is collected or stored. Model outputs are probability scores — not individual identifiers. Unauthorized disclosure has limited adverse effect.
Integrity	Moderate	Tampering with training data, model artifacts, or preprocessing pipelines could produce biased or inaccurate income predictions with serious downstream mission impact. Loss of integrity has serious adverse effect.
Availability	Low	IRSS is a decision-support tool. Temporary unavailability of the SageMaker endpoint delays but does not prevent mission operations. Local inference via the full sklearn Pipeline artifact remains available.
Overall System Impact	MODERATE	High water mark driven by Integrity. NIST SP 800-53 Rev. 5 Moderate baseline controls apply.

1.3 System Description

The Income Risk Scoring System (IRSS) is a production-grade MLOps pipeline that performs binary income-based risk classification on 2023 U.S. Census Bureau American Community Survey (ACS) Public Use Microdata Sample (PUMS) data. The system predicts whether an individual's annual wage income meets or exceeds $75,000 — approximating the 2023 U.S. median household income.

The pipeline spans the full ML lifecycle: data ingestion via Census API, feature engineering and preprocessing, progressive model training with automated fairness enforcement, MLflow model registry, SageMaker real-time endpoint deployment, and Evidently AI drift monitoring with CloudWatch alarming. All infrastructure is provisioned via Terraform — no manual console configuration exists.

IRSS is a decision-support tool. Model outputs are probability scores intended to support, not replace, human judgment. Human review is required before any consequential action is taken on model output.

1.4 System Boundary and Authorization Boundary

The IRSS authorization boundary encompasses all components within the AWS account in the us-east-1 region. The following components are within scope:

Component	Type	Description
Pipeline scripts (ingest, preprocess, train, evaluate, register)	Application Software	Python MLOps pipeline — Census API ingestion through MLflow registration
deploy.py / app.py (Streamlit)	Application Software	SageMaker deployment script and Streamlit demonstration interface
drift_monitor.py	Application Software	Evidently AI drift detection with CloudWatch integration
S3 — responsible-risk-engine-raw-data-*	Storage	Raw ACS PUMS parquet artifacts
S3 — responsible-risk-engine-processed-*	Storage	Preprocessed features, encoders, scaler artifacts
S3 — responsible-risk-engine-models-*	Storage	Trained model artifacts for SageMaker deployment
SageMaker Endpoint — responsible-risk-engine-prod-v1	Serving	Real-time inference endpoint — AWS XGBoost managed container
IAM Role — responsible-risk-engine-sagemaker-execution	Identity	Execution role with least-privilege S3 and CloudWatch permissions
CloudWatch — ResponsibleRiskEngine/Drift	Monitoring	Drift metrics and three operational alarms
MLflow Registry (local)	Experiment Tracking	Model versioning, lineage, and artifact storage
GitHub Actions CI/CD	Automation	Lint and structure validation on every push to main

The following components are external to the authorization boundary:

- U.S. Census Bureau API (api.census.gov) — external data source, read-only, public data
- GitHub.com — source code repository, external service
- PyPI / npm package repositories — dependency sources at build time only

1.5 User Roles and Access

Role	Access Level	Responsibilities
AI Architect / System Owner	Full — AWS account, GitHub owner	Pipeline development, deployment approval, fairness review, ATO maintenance
ML Engineer	Developer — AWS IAM constrained, GitHub write	Model training, evaluation, registry management
Responsible AI Reviewer	Read-only — fairness reports, drift reports	Monthly fairness drift review, escalation authority
SageMaker Execution Role (service)	IAM service role — S3 read/write, CloudWatch write	Endpoint operation, artifact retrieval, metric publishing
CI/CD Service Account	Limited — lint and structure only	Automated pipeline validation — no deployment authority

1.6 Security Control Implementation

The following controls from the NIST SP 800-53 Rev. 5 Moderate baseline are implemented, selected for relevance to an AI/ML pipeline operating on public microdata in a cloud environment.

Access Control (AC)

Control	Name	Implementation
AC-2	Account Management	AWS IAM provides role-based access control. The SageMaker execution role is scoped to least-privilege S3 and CloudWatch permissions only. No shared credentials. GitHub repository access is owner-controlled with branch protection on main.
AC-3	Access Enforcement	IAM policies enforce access at the resource level. S3 buckets are private with no public access. SageMaker endpoint invocation requires AWS Signature Version 4 authentication. MLflow runs locally with no network exposure.
AC-17	Remote Access	All AWS API calls use HTTPS (TLS 1.2+). No SSH or console-based access to production infrastructure. Terraform applies changes via AWS CLI with MFA-enabled credentials.

Audit and Accountability (AU)

Control	Name	Implementation
AU-2	Event Logging	CloudWatch captures all SageMaker endpoint invocations, errors, and latency. Three alarms are defined in Terraform: endpoint-availability, invocation-errors, model-latency. AWS CloudTrail logs all API calls within the account.
AU-12	Audit Record Generation	MLflow generates an immutable audit record for every model training run — hyperparameters, metrics, fairness results, and artifacts. Decision log DL-001 through DL-016 provides a human-readable audit trail of all architectural decisions with rationale.

Configuration Management (CM)

Control	Name	Implementation
CM-2	Baseline Configuration	All infrastructure defined in Terraform (infrastructure/main.tf). No manual console configuration. terraform plan produces a diff before any change is applied. SageMaker SDK constrained to >=2.200.0,<3.0.0 per DL-010.
CM-6	Configuration Settings	All pipeline parameters centralized in config.py — no hardcoded values in pipeline scripts. Sensitive credentials stored in .env (gitignored). .env.example provides a credential template without values.
CM-8	System Component Inventory	Terraform outputs.tf enumerates all AWS resource ARNs. Architecture.md documents the full technology stack. requirements.txt is the canonical dependency inventory.

Incident Response (IR)

Control	Name	Implementation
IR-4	Incident Handling	CloudWatch alarms trigger SNS notifications on endpoint errors, availability loss, and latency spikes. Runbook.md Section 5 defines the drift alert response procedure. Runbook.md Section 4 defines the fairness gate failure recovery procedure.
IR-6	Incident Reporting	Fairness gate failures are logged as GitHub Actions CI/CD failures and visible in the repository Actions tab. Drift alerts publish to CloudWatch and trigger SNS. Decision log captures root cause findings for significant incidents.

Risk Assessment (RA)

Control	Name	Implementation
RA-3	Risk Assessment	Risk Assessment Report (Part 3 of this package)

Control	Name	Implementation
		documents threat sources, likelihood, impact, and residual risk specific to an ML pipeline. The fairness audit quantifies demographic risk per group.
RA-5	Vulnerability Monitoring	GitHub Actions runs flake8 on every push. Dependency pinning limits supply chain exposure. SageMaker managed containers are patched by AWS. All dependency versions are pinned in requirements.txt.

System and Communications Protection (SC)

Control	Name	Implementation
SC-8	Transmission Confidentiality and Integrity	All Census API calls and AWS service calls use HTTPS (TLS 1.2+). SageMaker endpoint invocations use HTTPS. No unencrypted data transmission exists in the pipeline.
SC-28	Protection of Information at Rest	S3 buckets use AWS-managed AES-256 server-side encryption (SSE-S3) by default. Model artifacts stored in S3 are encrypted at rest. Local MLflow artifacts are protected by host OS file permissions.

System and Information Integrity (SI)

Control	Name	Implementation
SI-2	Flaw Remediation	Dependency versions pinned in requirements.txt. Known breaking changes documented in decision log DL-010 (SageMaker 3.x migration deferred). GitHub Dependabot alerts monitored for security advisories.
SI-4	System Monitoring	Evidently AI drift_monitor.py provides continuous monitoring of input feature distributions against training baseline. CloudWatch namespace ResponsibleRiskEngine/Drift publishes 9 metrics per monitoring run. Three operational CloudWatch alarms are active when the endpoint is deployed.

AI-Specific Controls (NIST AI RMF 1.0)

Control	Name	Implementation
GOVERN 1.1	Policies and Procedures	Fairness gate in evaluate.py blocks deployment on fairness failure — policy enforced through code, not documentation alone. Decision log provides an auditable trail of all design decisions.
MEASURE 2.5	Bias and Fairness Evaluation	evaluate.py computes PPR, AUC-ROC, precision, recall, and F1 across 10 demographic groups (race, sex, nativity) for every model version. Gate threshold: ±0.20 PPR deviation. Virginia audit result: PASSED.
MANAGE 1.3	Deployment Approval	Multi-stage approval: (1) automated AUC gate

Control	Name	Implementation
	Gate	>=0.82, (2) automated fairness gate ±0.20 PPR, (3) manual MLflow registry promotion to staging, (4) explicit deploy.py execution. No automated production promotion path exists.

1.7 Continuous Monitoring Strategy

IRSS implements a continuous monitoring strategy aligned with NIST SP 800-137. Monitoring covers infrastructure health, data quality, and AI-specific drift and fairness dimensions.

Monitoring Area	Tool	Frequency and Threshold
Feature drift — input distribution	Evidently AI + CloudWatch	Daily when endpoint is active. Alert if drift_share > 0.20 (DL-015).
Fairness drift — per-group PPR	drift_monitor.py	Monthly manual review. Alert if any group PPR delta exceeds ±0.15.
Endpoint availability	CloudWatch alarm	Continuous. Alert if invocations drop to zero.
Endpoint error rate	CloudWatch alarm	Continuous. Alert if more than 5% of requests return errors.
Endpoint latency	CloudWatch alarm	Continuous. Alert if p99 latency exceeds 2000ms.
Model registry integrity	MLflow	On every retrain. New version must pass AUC and fairness gates before promotion.
Dependency security	GitHub Dependabot	Continuous. Alerts on known CVEs in pinned dependencies.

Part 2 — Privacy Impact Assessment (PIA)

Reference: E-Government Act of 2002 Section 208 | OMB M-03-22 | Privacy Act of 1974

2.1 System Overview

This Privacy Impact Assessment (PIA) is prepared in accordance with Section 208 of the E-Government Act of 2002, which requires federal agencies to conduct PIAs before developing or procuring information technology that collects, maintains, or disseminates information in identifiable form. This PIA covers IRSS v1.0.

2.2 What Information Is Collected and Why

IRSS operates exclusively on 2023 U.S. Census Bureau American Community Survey Public Use Microdata Sample (ACS PUMS) data. ACS PUMS is a publicly available, de-identified microdata file released by the Census Bureau. No record corresponds to a uniquely identifiable individual.

Data Element	Purpose and Privacy Consideration
Age (continuous)	Model feature — labor market income predictor. Non-sensitive in isolation.
Education (categorical, encoded)	Model feature — encoded ordinal. Non-sensitive in isolation.
Occupation (categorical, encoded)	Model feature — Census occupation code, encoded. Non-sensitive in isolation.
Hours per week (continuous)	Model feature — dominant income predictor. Non-sensitive in isolation.
Class of worker (categorical, encoded)	Model feature — employment class. Non-sensitive in isolation.
Marital status (categorical, encoded)	Model feature — potentially sensitive in combination; used solely as a labor market predictor.
Person weight (continuous)	Census sampling weight — used as XGBoost sample_weight only. Not a model feature. Excluded from all model inputs (DL-004, DL-007).
Race (categorical)	NOT a model feature. Physically separated at preprocessing. Used exclusively for post-prediction fairness audit. Never stored with model predictions.
Sex (categorical)	NOT a model feature. Physically separated at preprocessing. Used exclusively for post-prediction fairness audit. Never stored with model predictions.
Nativity (native/foreign born)	NOT a model feature. Physically separated at preprocessing. Used exclusively for post-prediction fairness audit. Never stored with model predictions.
Wage income (binary target)	Derived binary label — 1 if wage income >= $75,000, else 0. Stored only in processed parquet files on the local development system.

2.3 Is the Information Personally Identifiable?

ACS PUMS microdata is not PII as defined by OMB M-07-16. The Census Bureau removes direct identifiers (name, Social Security number, address) before release. Geographic identifiers in PUMS are limited to PUMA (Public Use Microarea) — areas with populations of at least 100,000 — preventing geographic identification of individuals.

However, the combination of demographic attributes could theoretically increase re-identification risk for individuals in small demographic strata. IRSS mitigates this through the following measures:

- Sensitive features (race, sex, nativity) are never used as model inputs — they are physically separated from training data and used only for aggregate audit reporting.
- Groups with fewer than 30 records in the test set are excluded from fairness reporting — metrics at very small sample sizes present higher re-identification risk.
- Model outputs are probability scores only — individual record predictions are not stored or logged.
- No attempt is made to link PUMS records to external data sources.

2.4 Data Minimization

IRSS ingests only the 9 variables required for training and fairness auditing, as defined in config.py, from a dataset of approximately 200 available variables per person record. All other variables are discarded at ingestion time and never written to disk. The raw wage income value is converted to a binary label at preprocessing — the continuous income value is not retained in processed artifacts.

2.5 Data Retention and Disposal

Artifact	Retention Policy
Raw parquet (data/raw/)	Retained for active development cycle. Deleted when pipeline is decommissioned. S3 raw bucket cleared on terraform destroy.
Processed parquet (data/processed/)	Retained for active training cycle. Regenerated on each new ACS data release. Local only — not transmitted externally.
Sensitive parquet (sensitive_*.parquet)	Retained for active fairness audit cycle only. Contains race, sex, nativity — handled with heightened care. Deleted at end of each evaluation run.
Model artifacts (models/*.joblib, *.json)	Retained in MLflow registry for audit trail. S3 models bucket cleared on terraform destroy.
Drift reports (reports/drift_report_*.html)	Retained for 90 days from generation. Aggregate statistics only — no individual records.
CloudWatch metrics	Default AWS retention: 15 months. Aggregate statistics only — no individual records.

2.6 Sensitive Attribute Handling

The handling of race, sex, and nativity in IRSS is explicitly designed to prevent protected attributes from influencing model predictions while enabling post-prediction fairness auditing. This design satisfies the intent of Executive Order 13985 (Advancing Racial Equity) and OMB AI guidance.

The separation is enforced in code (src/data/preprocess.py) and verified at the evaluation stage (src/training/evaluate.py). The sensitive parquet file is rejoined to predictions only in evaluate.py — the model itself never receives these attributes. This is documented in Decision Log DL-014 and mapped to NIST AI RMF GOVERN 1.7 in docs/nist_alignment.md.

2.7 Privacy Risk Summary

Privacy Risk	Risk Level	Mitigation
Re-identification of individuals from PUMS microdata	Low	PUMS is de-identified public data. Geographic identifiers limited to PUMA (100K+ population). Small groups excluded from fairness reporting.
Model outputs exposing sensitive inferences about individuals	Low	Outputs are aggregate probability scores. No individual predictions stored or logged.
Sensitive attributes influencing model decisions	Low — Mitigated	Race, sex, nativity physically separated from model inputs in code. Audit-only rejoined in evaluate.py.
Unauthorized access to sensitive parquet files	Low — Mitigated	Files stored locally. S3 buckets private with IAM-enforced access and AES-256 encryption. Sensitive parquet deleted after each audit cycle.
Data breach of AWS S3 artifacts	Low	S3 buckets private by default. AES-256 SSE-S3 encryption. IAM least-privilege access. No PII in any S3 artifact.

Part 3 — Risk Assessment Report (RAR)

Reference: NIST SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments

3.1 Purpose and Scope

This Risk Assessment Report (RAR) is prepared in accordance with NIST SP 800-30 Rev. 1. It identifies threat sources and threat events relevant to IRSS, assesses the likelihood and impact of identified risks, documents existing controls and their effectiveness, and determines residual risk levels. The assessment covers the full IRSS pipeline and is bounded by the authorization boundary defined in SSP Section 1.4.

3.2 System Characterization

IRSS is a Moderate-impact system (FIPS 199) operating on public microdata in a cloud environment. The system does not process classified information, PII in identifiable form, or financial transaction data. The primary asset requiring protection is the integrity of the trained model and its training pipeline — model tampering could produce biased or inaccurate predictions with downstream mission impact.

3.3 Risk Determination

Risk ratings use a 3x3 matrix per NIST SP 800-30 Table I-2. Likelihood and Impact are rated Low, Medium, or High. Overall Risk = Likelihood x Impact.

Threat Event	Likelihood	Impact	Risk	Controls and Residual Risk
Data poisoning — adversarial manipulation of ACS PUMS source data	Low	High	Low-Med	ACS PUMS published by U.S. Census Bureau — authoritative source with no direct write access. Annual ACS refresh provides natural re-validation. Residual risk: Low.
Training data leakage — sensitive features contaminating model inputs	Low	High	Low-Med	Sensitive features physically separated in preprocess.py before train/test split. Fairness audit in evaluate.py would detect systematic leakage. Code-enforced separation with audit trail. Residual risk: Low.
Model inversion attack — reconstructing training data from model outputs	Low	Low	Low	Outputs are probability scores only — not model weights. Endpoint requires AWS authentication. Training data is public ACS PUMS — model inversion provides no private information gain. Residual risk: Negligible.

Threat Event	Likelihood	Impact	Risk	Controls and Residual Risk
Adversarial input manipulation — crafted inputs to exploit model boundaries	Low	Medium	Low	IRSS is a decision-support tool with human review required. Adversarial inputs do not produce safety-critical outcomes. Input validation at preprocessing rejects out-of-range values. Residual risk: Low.
Supply chain compromise — malicious dependency in requirements.txt	Low-Med	High	Medium	Dependencies pinned to specific versions (DL-010). GitHub Dependabot monitors for known CVEs. SageMaker managed containers patched by AWS. Residual risk: Medium — mitigated but not eliminated.
MLflow registry tampering — unauthorized model version promotion	Low	High	Low-Med	MLflow runs locally with no network exposure. No automated production promotion path. Human sign-off required before any deployment (Runbook Section 7). Residual risk: Low.
Model drift — degradation of prediction accuracy over time	Medium	Medium	Medium	Evidently AI detects input distribution shift. CloudWatch alarm fires when drift_share > 0.20. Retraining triggered manually after human review (DL-015). Model performance drift (requires ground truth labels) not yet monitored — tracked in POA-001. Residual risk: Medium.
Fairness degradation — demographic disparity exceeding gate threshold	Low	High	Low-Med	Fairness gate in evaluate.py blocks deployment on failure. Monthly monitoring with ±0.15 early warning threshold. Recovery procedure in DL-016 and Runbook Section 4. Residual risk: Low.
Unauthorized SageMaker endpoint access	Low	Medium	Low	Endpoint requires AWS Signature Version 4 authentication. IAM role scoped to least-privilege. No public endpoint exposure. Residual risk: Low.
S3 artifact exfiltration	Low	Low	Low	S3 buckets private by default. IAM-enforced access. AES-256 SSE encryption. Artifacts are public ACS PUMS data and model weights — no PII. Residual risk: Negligible.
CI/CD pipeline compromise — malicious code injected via pull request	Low	Medium	Low	GitHub branch protection on main requires pull request review. CI/CD runs lint and structure validation only — no deployment authority in the automated pipeline. Residual risk: Low.

3.4 Risk Summary

Risk Level	Count	Items
High	0	None identified at this level given existing controls.
Medium	2	(1) Supply chain compromise — dependency vulnerabilities; (2) Model drift — ground truth not available for model performance monitoring (POA-001).
Low / Low-Medium	9	All other identified threat events — mitigated to acceptable residual risk by existing controls.

3.5 Risk Acceptance

The Authorizing Official (Raghunath Devayajanam, AI Architect) accepts the residual risk profile documented above for the Virginia (FIPS 51) pilot deployment of IRSS v1.0. The two Medium-risk items are tracked in the Plan of Action and Milestones (Part 4) with documented remediation timelines. This risk acceptance is contingent on the continuous monitoring controls described in SSP Section 1.7 remaining operational throughout the ATO period.

Part 4 — Plan of Action and Milestones (POA&M)

Reference: OMB M-02-01 | NIST SP 800-53 Rev. 5 CA-5

4.1 Overview

The Plan of Action and Milestones (POA&M) documents known weaknesses, gaps, and deferred items identified during the development, testing, and risk assessment of IRSS v1.0. Each item includes the source (decision log reference, risk assessment finding, or control gap), severity, remediation plan, and target completion date.

The POA&M is reviewed at each quarterly checkpoint and before any system change that affects the authorization boundary. The Authorizing Official must concur on any new High-severity items before continued operation.

4.2 Open Items

ID	Weakness Description	Severity	Source	Remediation Plan and Target Date
POA-001	Model performance drift not monitored. Ground truth labels are not collected post-deployment. Evidently AI monitors input distribution drift only — degradation in prediction accuracy cannot be detected without known outcomes.	Medium	RAR Sec. 3.3 | Architecture.md	Implement delayed label collection. Capture actual income outcomes after a defined lag period. Recompute AUC and fairness metrics against live predictions. Trigger retraining if AUC drops below 0.82. Target: National deployment phase.
POA-002	Client-side preprocessing contract. SageMaker endpoint receives preprocessed inputs. Callers must apply ACSPreprocessor before invocation. Mismatched preprocessing produces silent prediction errors with no endpoint-side validation.	Low-Med	DL-014 | Model Card	Implement schema validation at the preprocessing step — enforce feature order, type, and value range before inputs reach the endpoint. Evaluate moving preprocessing inside the container when SageMaker 3.x migration is completed (POA-004). Target: Q3 2026.
POA-003	Dual model format maintenance. Two model artifacts maintained: xgboost_native.json for SageMaker serving and full_pipeline_*.joblib for local inference. Risk of version drift between the two artifacts.	Low	DL-011 | Architecture.md	Consolidate to a single artifact when SageMaker 3.x ModelBuilder API is validated. Until then, register.py version-stamps both artifacts and MLflow provides a single audit trail linking both to the same training run. Target: SageMaker 3.x migration.
POA-	SageMaker SDK pinned to	Low	DL-010	Evaluate SageMaker 3.x

ID	Weakness Description	Severity	Source	Remediation Plan and Target Date
004	2.x, which will reach end of vendor support. Migration to SageMaker 3.x ModelBuilder API required — all framework-specific classes (XGBoostModel, SKLearnModel) are removed in 3.x.			ModelBuilder API when documentation matures. Run a parallel deployment test before migrating production. Update requirements.txt constraint and deploy.py implementation. Decision log entry required. Target: Q4 2026.
POA-005	Equalized odds not measured. Current fairness gate uses Positive Prediction Rate (PPR) delta only. Equal true positive rates and false positive rates across groups — the equalized odds criterion — are not computed or enforced.	Low-Med	DL-009 | NIST AI RMF MEASURE 2.5	Add equalized odds computation to evaluate.py. Compute TPR and FPR per demographic group. Determine whether a gate threshold is applied or metrics are reported only. Update fairness_report.md. Target: Q2 2026.
POA-006	SHAP per-record explanations not implemented. Feature importance reported at aggregate model level only. Per-record explanations using SHAP are documented as planned but not yet built.	Low	NIST AI RMF MEASURE 4.1 | Model Card	Implement SHAP explainer in the Streamlit demo (app.py). Display per-record feature contribution waterfall for each prediction. Evaluate logging SHAP values to MLflow alongside model artifacts. Target: Q2 2026.
POA-007	Retraining automation not implemented. Current retrain trigger is manual — a CloudWatch alarm notifies an engineer who initiates retraining after human review. EventBridge/Lambda infrastructure is referenced in architecture.md but retrain_trigger.py is not implemented.	Low	DL-015 | Architecture.md	Implement retrain_trigger.py — EventBridge rule fires on CloudWatch drift alarm, Lambda initiates the retraining pipeline. Human approval gate before production promotion is retained. Target: National deployment phase.
POA-008	American Indian demographic group — small sample size in Virginia data. Only 68 records in the test set. Fairness metrics for this group are unreliable. Model may over-predict high income for this group (Precision 0.375, Recall 0.90).	Low-Med	DL-009 | Fairness Report	Flag for priority review after national data pull (STATE_CODE='*'). National dataset will provide a substantially larger sample. Do not cite Virginia fairness results for this group as representative. Target: National deployment phase.

4.3 Closed Items

ID	Weakness	Resolution
CLOSED-001	AWS Account ID and SageMaker endpoint URLs exposed in source code	Scrubbed from all source files. Git history cleaned using git filter-repo. .env.example provides credential template without values. CI/CD updated to fail on missing required files. Verified clean.
CLOSED-002	person_weight passed through StandardScaler, producing negative values rejected by XGBoost	StandardScaler applied to age and hours_per_week only. person_weight passed as raw values to XGBoost sample_weight parameter. DL-007 documents decision and rationale.
CLOSED-003	SageMaker deployment failure — joblib artifact incompatible with XGBoost managed container	Root cause identified after 15 deployment attempts. Resolved by saving model in native XGBoost JSON format. Endpoint reached InService in 4 minutes. DL-011 documents the full root cause analysis.

Part 5 — AI Impact Assessment

Reference: Executive Order 13960 | OMB M-21-06 | NIST AI RMF 1.0 | NIST SP 800-53 Rev. 5

5.1 Purpose

This AI Impact Assessment (AIIA) evaluates the specific risks, limitations, and governance requirements associated with the artificial intelligence components of IRSS. It supplements the SSP and RAR with AI-specific analysis required under Executive Order 13960 and OMB M-21-06.

5.2 AI System Categorization

Attribute	Assessment
AI System Type	Supervised machine learning — binary classification (XGBoost gradient boosted trees)
Decision Type	Decision-support — probability scores only. Human review required before consequential action.
Automation Level	Semi-automated. Model produces a probability score; a human makes the final determination.
Affected Population	U.S. working-age adults (18+) represented in ACS PUMS Virginia data. National expansion planned.
Consequential Use	Low-to-Moderate. Model output is one input to a screening process — not the sole basis for adverse action.
Domain	Income classification / labor market analysis
Training Data Source	U.S. Census Bureau ACS PUMS 2023 — authoritative government microdata
Deployment Scope	Virginia (FIPS 51) pilot — 88,928 records. National expansion is a documented future enhancement.

5.3 Human-in-the-Loop Documentation

IRSS is explicitly designed as a decision-support system. Human oversight is embedded at three distinct stages:

Stage	Human Oversight Requirement
Pre-deployment — Fairness Review	The AI Architect or designated Responsible AI Reviewer must review per-group fairness results before any deployment. MLflow registry promotion requires explicit human action — no automated promotion path exists (NIST AI RMF MANAGE 1.3).
Pre-deployment — Production Approval	deploy.py requires explicit execution by an authorized engineer. The script presents a confirmation prompt before finalizing the endpoint, providing a final review window before the model is live.

Stage	Human Oversight Requirement
Inference — Decision Application	Model Card and Runbook explicitly state that model output is one input to a human review process. Any consequential action based on model output requires human determination. This constraint is documented in the model card intended use section.

5.4 Explainability Posture

Explainability Dimension	Current Implementation
Global feature importance	XGBoost feature_importances_ logged to MLflow on every training run. Top features: hours_per_week (0.44), occupation (0.17), education (0.14), class_of_worker (0.11), age (0.07), marital_status (0.06).
Model progression justification	Three-stage progressive training (Logistic Regression, Ridge, XGBoost) documents the complexity narrative. XGBoost selected based on demonstrated AUC improvement of +0.0398 and F1 improvement of +0.1125 over the logistic regression baseline (DL-008).
Decision audit trail	DL-001 through DL-016 provide an auditable record of every design decision with explicit tradeoffs, available to oversight bodies on request.
Per-record explanation (SHAP)	Not yet implemented. Tracked in POA-006 with target completion Q2 2026.

5.5 Bias and Fairness Risk Assessment

Bias is the primary AI-specific risk in IRSS. The system makes income predictions across demographic groups where historical income disparities exist in the underlying data. The model cannot be expected to eliminate underlying data disparities, but it must not introduce additional disparity beyond what exists in the data.

Bias Risk Dimension	Assessment and Mitigation
Historical bias in training data	ACS PUMS 2023 reflects actual income distributions in the Virginia labor market, including documented wage gaps by race and sex. The fairness audit distinguishes model-introduced disparity from data-reflected disparity by comparing per-group AUC (predictive quality) against PPR (prediction rate). Equal AUC across groups with different PPR indicates the model predicts with equivalent accuracy — the disparity is in the underlying data, not the model.
Algorithmic amplification	scale_pos_weight=2.43 addresses class imbalance (78/22 majority/minority split) without demographic weighting. Sensitive features are never model inputs — no direct path exists for protected attributes to influence predictions.
Disparate impact	PPR delta gate (±0.20) enforced in CI/CD. Virginia audit result: PASSED. Largest inter-group gap: Black or African American (PPR 0.171) vs Asian (PPR 0.413) — 0.242 absolute gap. Both pass the gate individually. Gap reflects Virginia 2023 income distribution. Monitoring commitment: per-group PPR tracked monthly with ±0.15 early warning threshold.
Small group reliability	American Indian group (N=68 in Virginia test set) flagged for unreliable

Bias Risk Dimension	Assessment and Mitigation
	metrics. Groups with fewer than 30 records excluded from fairness reporting. National data pull required for representative results (POA-008).

5.6 NIST AI RMF 1.0 Control Summary

IRSS is aligned with the NIST AI Risk Management Framework 1.0 across the four framework functions: GOVERN, MAP, MEASURE, and MANAGE. Full implementation details are documented in docs/nist_alignment.md.

Control ID	Control Name	Status	Key Implementation Evidence
GOVERN 1.1	Policies and Procedures	Implemented	Fairness gate in evaluate.py. Decision log DL-001 to DL-016.
GOVERN 1.4	Model Versioning and Lineage	Implemented	MLflow registry — income-risk-xgboost, alias staging. Full run lineage.
GOVERN 1.7	Sensitive Attribute Handling	Implemented	Physical separation in preprocess.py. Audit-only rejoined in evaluate.py.
MAP 1.1	Use Case Scoping	Implemented	Income threshold documented in config.py and DL-002. Affected population defined.
MAP 2.1	Risk Identification	Implemented	Risk table in nist_alignment.md. RAR Section 3.3 of this package.
MAP 5.1	Impact Assessment	Implemented	Per-group fairness audit in fairness_report.md.
MEASURE 2.5	Bias and Fairness Evaluation	Implemented	evaluate.py — PPR, AUC, F1 per demographic group. Virginia: PASSED.
MEASURE 2.6	Performance Monitoring	Implemented	drift_monitor.py — Evidently AI + CloudWatch. 9 metrics published per run.
MEASURE 2.7	Fairness Gate Enforcement	Implemented	evaluate.py exits code 1 on failure — blocks CI/CD pipeline.
MEASURE 4.1	Explainability	Partial	Global feature importance implemented. SHAP per-record pending — POA-006.
MANAGE 1.3	Deployment Approval Gate	Implemented	Multi-stage: AUC gate + fairness gate + manual MLflow promotion + explicit deploy.py.
MANAGE 2.2	Risk Response Documentation	Implemented	fairness_report.md — findings and risk response commitments.
MANAGE 2.4	Ongoing Monitoring	Implemented	drift_monitor.py + three CloudWatch alarms in Terraform.
MANAGE 4.1	Retraining Triggers	Implemented	DL-015 — drift_share > 0.20, AUC < 0.82, fairness drift > ±0.15.

Part 6 — Security Assessment Plan (SAP)

Reference: NIST SP 800-53A Rev. 5 — Assessing Security and Privacy Controls in Information Systems and Organizations

6.1 Purpose and Scope

This Security Assessment Plan (SAP) describes the approach, scope, and test procedures for assessing the security and privacy controls implemented in IRSS v1.0, prepared in accordance with NIST SP 800-53A Rev. 5. The assessment covers the controls documented in SSP Section 1.6 and the AI-specific controls documented in Part 5. Assessment methods include documentation examination, system owner interview, and automated control testing.

6.2 Assessment Team

Role	Responsibilities
Lead Assessor	Raghunath Devayajanam — System Owner and AI Architect. Conducts self-assessment for portfolio purposes. In a production ATO, this role would be filled by an independent assessor or third-party assessment organization (3PAO) per NIST SP 800-37 Rev. 2 Section 2.5.
Technical Reviewer	Independent technical reviewer — reviews code, configuration, and documentation against stated controls. In a production ATO, this role would be filled by a security engineer independent of the development team.

6.3 Assessment Methods

- Examine — review of documentation: SSP, decision log, fairness report, model card, runbook, architecture.md, nist_alignment.md, Terraform configuration, requirements.txt, and GitHub Actions workflow.
- Interview — review of design decisions with the system owner against stated control intent.
- Test — execution of automated controls: fairness gate, drift monitor, CI/CD pipeline, and CloudWatch alarms.

6.4 Test Cases

Control	Assessment Objective	Test Procedure	Expected Result
AC-2 / AC-3	Verify IAM role is scoped to least privilege	Review IAM policy attached to the SageMaker execution role. Verify S3 permissions limited to specific bucket ARNs.	Policy grants only s3:GetObject and s3:PutObject on named buckets. CloudWatch PutMetricData on named namespace only. No administrative permissions.

Control	Assessment Objective	Test Procedure	Expected Result
		Verify no wildcard (*) actions.	
AU-2 / AU-12	Verify CloudWatch alarms are active and correctly configured	Run: aws cloudwatch describe-alarms for the three named alarms. Verify thresholds match Terraform configuration in main.tf.	Three alarms returned. State is OK or ALARM when endpoint is active. Thresholds match main.tf definitions exactly.
CM-2	Verify all infrastructure is defined in Terraform — no unmanaged resources	Run terraform plan against current AWS state. Compare Terraform state against AWS console.	terraform plan output: No changes. All resources accounted for in Terraform state.
CM-6	Verify no hardcoded credentials or account IDs in source code	Run grep for known AWS Account ID pattern and AKIA key pattern across src/ and config.py. Verify .env is not committed to the repository.	No matches found. AWS Account ID not present in any source file. .env is listed in .gitignore and absent from the repository.
SC-8	Verify all data in transit uses HTTPS	Review ingest.py Census API call. Review deploy.py SageMaker invocation. Review AWS SDK calls.	All external calls use HTTPS. No http:// URLs in pipeline code. AWS SDK enforces TLS 1.2+ by default.
SC-28	Verify S3 encryption at rest	Run: aws s3api get-bucket-encryption for each of the three S3 buckets.	All three buckets return ServerSideEncryptionConfiguration with AES256 rule. No unencrypted bucket policy.
MEASURE 2.5 / 2.7	Execute fairness gate and verify CI/CD blocking behavior	Run evaluate.py on Virginia test set. Verify exit code 0 (PASSED). Then set FAIRNESS_THRESHOLD=0.001 in config.py and re-run. Verify exit code 1 (FAILED). Restore threshold.	Normal run: exit code 0, PASSED message, per-group results printed. Threshold=0.001 run: exit code 1, FAILED message with flagged groups. GitHub Actions treats exit code 1 as pipeline failure.
MEASURE 2.6 / MANAGE 2.4	Execute drift monitor and verify CloudWatch publication	Run drift_monitor.py. Verify HTML report generated in reports/. Query CloudWatch for DriftShare metric.	HTML report saved to reports/drift_report_TIMESTAMP.html. CloudWatch returns DriftShare data point from the current run. 9 metrics visible in the ResponsibleRiskEngine/Drift namespace.
MANAGE 1.3	Verify no automated production promotion	Review GitHub Actions workflow file. Review	No deploy step in GitHub Actions workflow. register.py

Control	Assessment Objective	Test Procedure	Expected Result
	path exists	register.py — confirm model is promoted to staging only. Confirm deploy.py requires explicit execution.	sets alias to staging only. deploy.py must be run manually. No EventBridge, Lambda, or scheduled trigger for deployment.
GOVERN 1.7	Verify sensitive feature separation at preprocessing	Review preprocess.py — confirm race, sex, nativity are removed from X_train and X_test before model training. Review evaluate.py — confirm sensitive_df is only rejoined for audit, not passed to model.predict.	preprocess.py creates separate sensitive_*.parquet before train/test split. X_train and X_test columns do not include race, sex, or nativity. evaluate.py never passes sensitive_df to model.predict_proba.
GOVERN 1.4	Verify MLflow model lineage is complete	Open MLflow UI. Navigate to income-risk-xgboost experiment. Verify hyperparameters, metrics, fairness metrics, and artifacts are logged and model is registered with alias staging.	All hyperparameters logged. AUC, F1, per-group PPR and AUC logged. Model artifact and full_pipeline artifact attached. Registered as income-risk-xgboost with alias staging.
POA-005 (open)	Confirm equalized odds gap — document control gap	Review evaluate.py — verify TPR and FPR per group are not computed. Confirm POA-005 is tracked.	evaluate.py does not compute equalized odds metrics. POA-005 is documented with Q2 2026 target. Control gap confirmed and tracked.

6.5 Assessment Schedule

Assessment Activity	Target Date	Status
Documentation review (SSP, PIA, RAR, POA&M, AIIA)	March 2026	Complete — incorporated into this package
Technical control testing (CM, AC, SC, AU)	March 2026	Complete — results documented in Section 6.4
Fairness gate test execution	March 2026	Complete — Virginia audit PASSED
Drift monitor test execution	March 2026	Complete — baseline drift_share 0.0
POA&M open item verification	Quarterly	Ongoing — next review Q2 2026

Assessment Activity	Target Date	Status
Annual ATO re-assessment	March 2027	Scheduled — coincides with ACS 2024 data release
National deployment assessment	TBD — prior to national rollout	Pending — requires national fairness audit and updated RAR

6.6 Authorization Recommendation

Based on the security assessment results documented in this plan, the following findings support an Authorization to Operate recommendation for IRSS v1.0 under the Virginia pilot deployment scope:

- All High-priority controls are implemented and verified.
- No High-risk findings identified in the Risk Assessment Report.
- Fairness gate passed for Virginia development deployment — 0 of 10 demographic groups exceeded the ±0.20 PPR threshold.
- Eight open POA&M items identified — all rated Low or Low-Medium severity. No open items block ATO issuance. Remediation timelines are defined and tracked.
- Continuous monitoring controls are operational — CloudWatch alarms, Evidently AI drift monitoring, and monthly fairness drift review are in place.

Authorization condition: The ATO is issued for the Virginia (FIPS 51) pilot deployment only. National deployment (STATE_CODE='*') requires a separate authorization action, including a full national fairness audit, updated risk assessment, and Authorizing Official concurrence.

Authorization

Field	Value
Authorizing Official	Raghunath Devayajanam
Title	AI Architect
Authorization Date	March 2026
ATO Expiration	March 2028
Authorization Scope	Virginia (FIPS 51) pilot deployment only
Conditions	Continuous monitoring controls must remain operational. POA&M reviewed quarterly. National deployment requires separate authorization action.

Authorizing Official Signature | Date